

Mahmud Hasan Sizan

Offensive Security Researcher · Bug Bounty Hunter
(twistedmock)

twistedmock@wearehackerone.com ·

twistedmock.com

hackerone.com/twistedmock ·

bugcrowd.com/twistedmock

github.com/Twistedmock · linkedin.com/in/twistedmock

Remote worldwide or relocating · GMT+6

SUMMARY

Top-1,000 all-time researcher on HackerOne with six years hunting web-application vulnerabilities. **102 reports resolved across 67 programs, 100+ paid bounties**, and **HackerOne Clear** (background-checked). 84% of my reputation sits in 28 private, invitation-only programs — including one where I rank **#1 of every hunter on it**. Publicly credited by **Apple** (three times), **Goldman Sachs**, **SpaceX**, **GitHub** and **Adobe**.

3,447 REPUTATION	#807 GLOBAL RANK	102 RESOLVED	67 PROGRAMS	100+ PAID BOUNTIES	81st SIGNAL PCT.	84th IMPACT PCT.	6 yrs HUNTING
---------------------	---------------------	-----------------	----------------	--------------------------	---------------------	---------------------	------------------

PLATFORMS

- HackerOne — twistedmock** (since May 2020). 3,447 reputation, global rank #807, 102 resolved, signal 5.59 (81st percentile), impact 84th percentile. HackerOne Clear. 18 badges across six OWASP categories; Milestone Level III; seven-month valid-report streak (Jan–Jul 2026). 28 private programs hold 2,896 reputation — one at rank #1 with 48 valid reports.
- Bugcrowd — twistedmock**. 64 valid findings; public hall of fame at SpaceX, Atlassian, Twilio, Bitdefender, Coca-Cola, United Airlines, Lenovo, Ibotta, Monash University and the U.S. Department of Veterans Affairs; three further programs private.

PUBLIC ACKNOWLEDGEMENTS

- Apple** — named in Apple's security acknowledgements (web server security) in February 2026, August 2025 and July 2025. support.apple.com/en-us/102774
- Goldman Sachs** — two bounties awarded, 3 May and 24 April 2026 (one a collaboration).
- GitHub** — report resolved 28 September 2021; GitHub Security Researcher.
- UNESCO** — reflected XSS on unesco.org resources, acknowledged by name 19 June 2025; **Deutsche Telekom** — SSRF, credited on Telekom's public acknowledgements page.
- Adobe** — five valid reports; four resolved inside six weeks, February–March 2023.
- 30 public HackerOne programs** — incl. PayPal, Palantir, Databricks, Spotify, Roblox, UPS, Xiaomi, AT&T, Kubernetes, Hilton, Hyatt, Veeam and the U.S. GSA.

FOCUS AREAS

- Web application security** — authentication and session flaws, broken access control (IDOR, privilege escalation), injection, XXE, XSS, security misconfiguration. Each class confirmed by a HackerOne badge, issued only on a valid report of that class.
- Reconnaissance & attack-surface mapping** at estate scale — internet-wide asset discovery, subdomain and port intelligence without touching the target.
- AI-augmented pentesting** — personal harnesses built around Claude and Codex that run reconnaissance, triage, proof-of-concept drafting and reporting, with every exploitation step steered by me.
- Reporting** — clear reproduction, impact framing and remediation advice; 100+ reports triaged valid and paid by mature programs.

TOOLING (OPEN SOURCE, RUST)

- qshodan** — extracts hosts from Shodan and defeats its 1,000-result ceiling by recursive query subdivision; validates, strips reserved ranges, deduplicates. github.com/Twistedmock/qshodan
- qport** — port discovery from Shodan InternetDB at ~500 req/s; no packets reach the asset owner. github.com/Twistedmock/qport
- Attack Surface Monitoring** (SaaS, in development) — Crunchbase, Shodan, Censys, Whoxy and crt.sh folded into one continuous picture.

Claude	Codex	Rust	Python	Bash	Burp Suite
Shodan	Censys	crt.sh	Whoxy	Linux	

LANGUAGES

English (IELTS 8.0) · Bengali (native) · Hindi · Urdu

ROLES SOUGHT

Penetration tester · red team operator · application security engineer · vulnerability researcher · attack-surface / recon specialist. Full-time or contract; remote worldwide, or relocating.

All figures retrieved from the HackerOne and Bugcrowd APIs on 15 August 2026 and verifiable on the linked public profiles. Private programs are not named, as their terms require. Live version, with links: twistedmock.com — security contact per RFC 9116 at twistedmock.com/.well-known/security.txt.